NAME: THULASI S **ROLL:NO:241901118**

EXP 13: DETECT WEB APPLICATION VULNERABILITIES USING VARIOUS SECURITY TOOLS

AIM:

To use automated web vulnerability scanners to identify common security flaws in a target web application.

THEORY:

Manual testing is slow and can miss issues. Automated scanners crawl the entire application, send thousands of test payloads (SQLi, XSS, broken authentication, misconfigurations, outdated components, etc.), and generate a structured report ranking vulnerabilities by severity. These tools are essential in a professional VAPT (Vulnerability Assessment and Penetration Testing) workflow.

TOOLS REQUIRED:

1. Kali linux
2. OWASP ZAP (Zed Attack Proxy)
3. Nikto
4. Target: OWASP Juice Shop (or DVWA)

PROCEDURE:

Step 1 — Basic scan with Nikto

```
nikto -h http://<target-ip>:3000
```

Nikto checks for outdated server software, dangerous files, missing security headers, and default files.

Step 2 — Full scan using OWASP ZAP (GUI)

1. Open ZAP: zaproxy from terminal or Applications menu.
2. In the Quick Start tab, enter the target URL: http://<target-ip>:3000
3. Click Automated Scan.

4. ZAP will spider the site (map all pages) and then run an Active Scan, sending attack payloads to every input field found.

Step 3 — Review the Alerts tab

ZAP categorizes findings by risk: High, Medium, Low, Informational. Typical findings include:

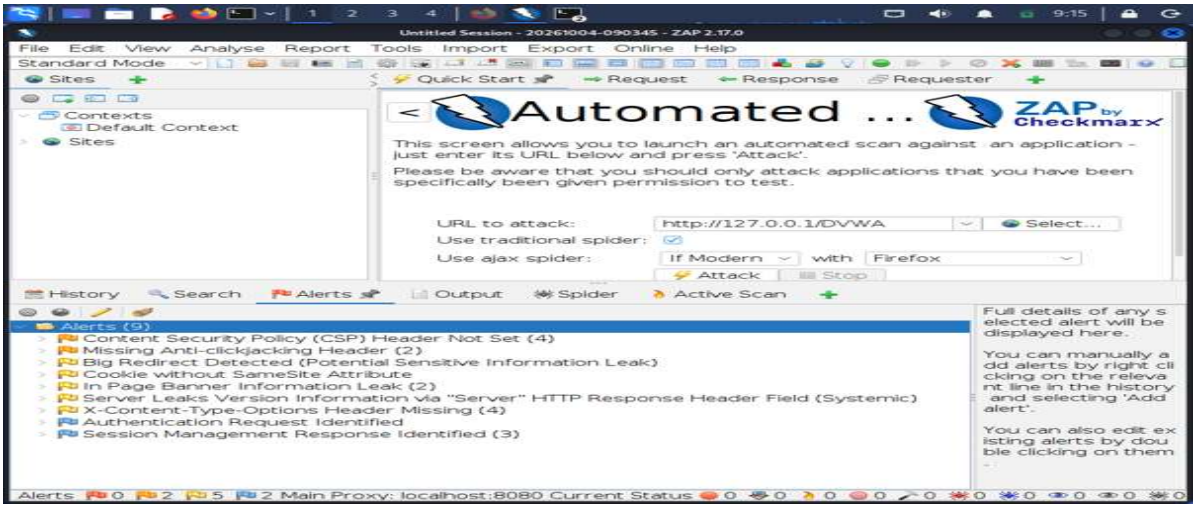
- Missing X-Frame-Options header (clickjacking risk)
- SQL Injection points
- Cross-Site Scripting points
- Missing CSRF tokens

Step 4 — Export the report

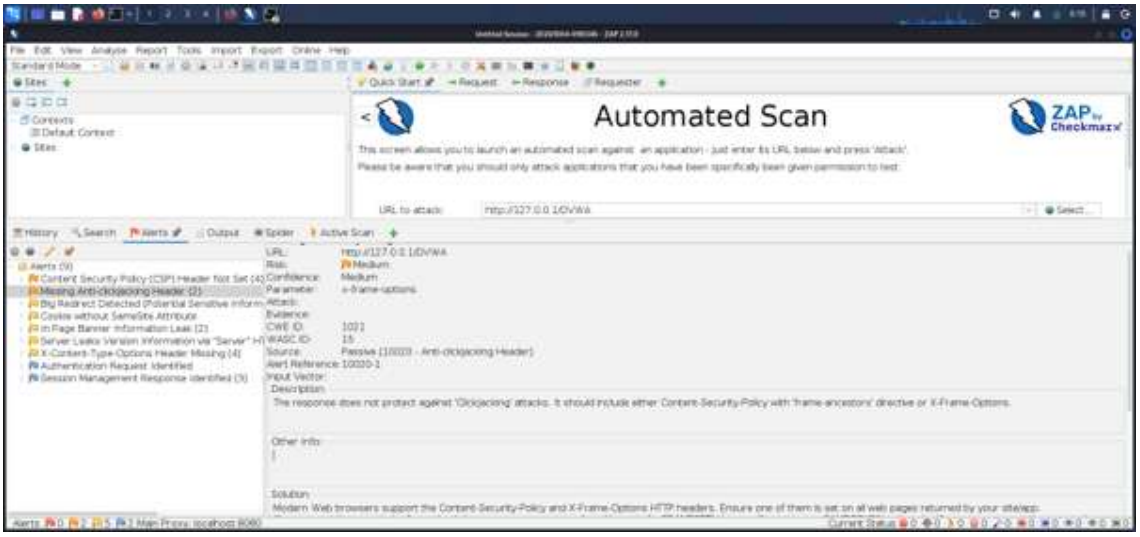
Report → Generate Report → HTML/PDF. This report format is what real pentesters submit to clients.

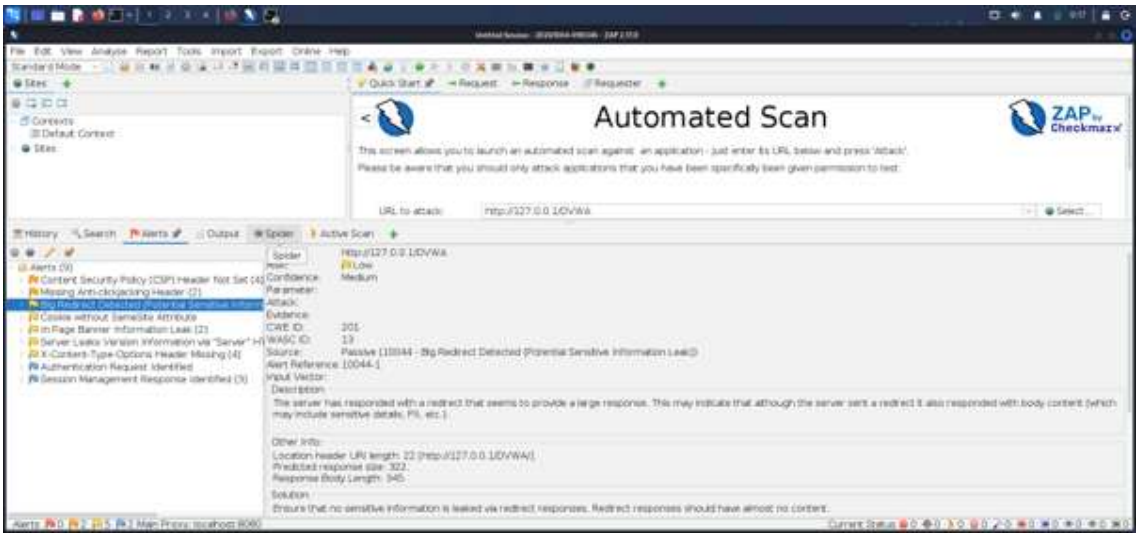
OUTPUT:

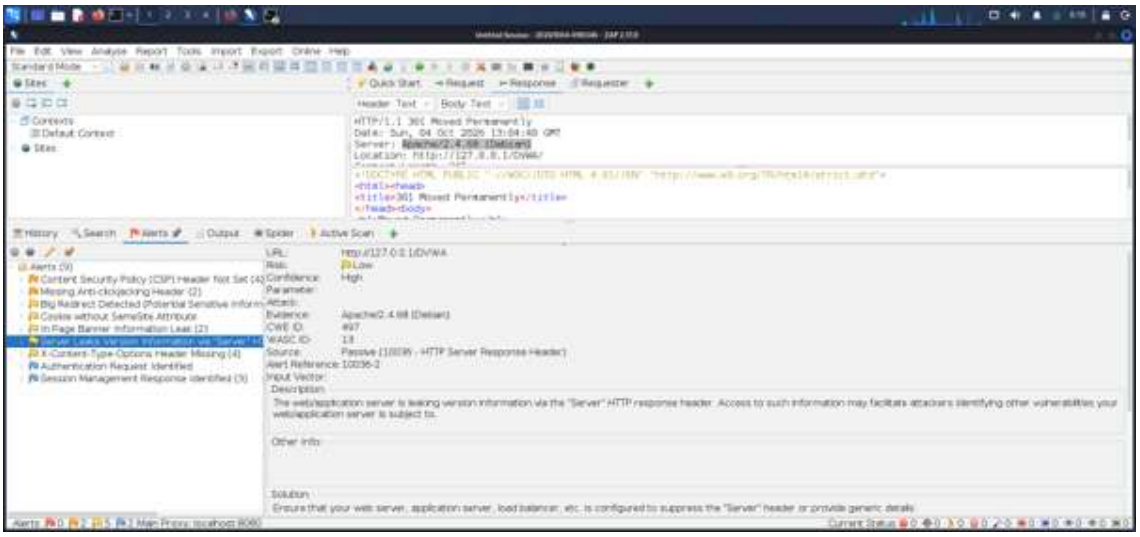
1.Alerts Tab

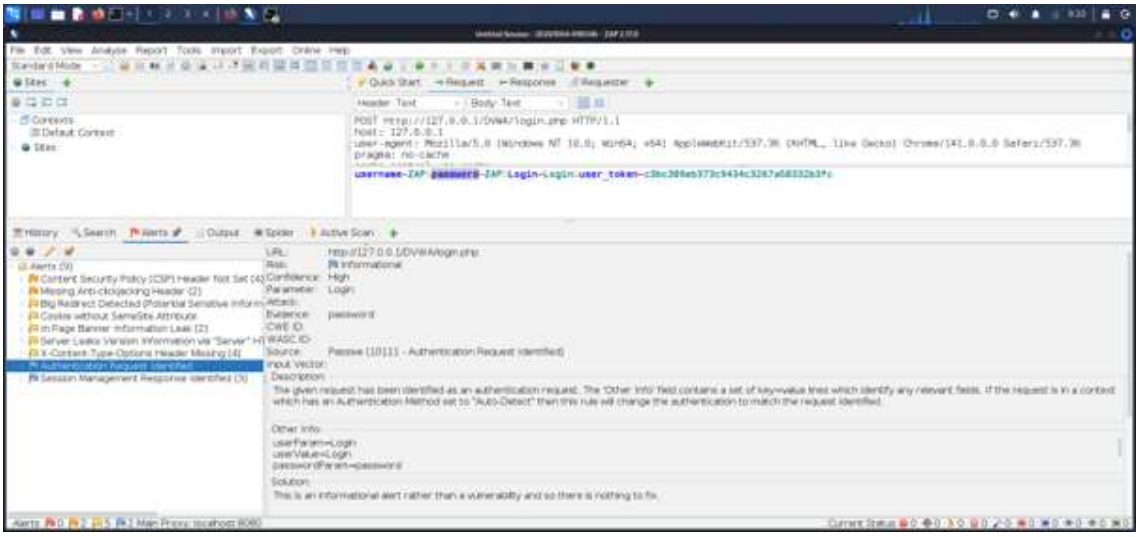


2. Alerts with Description









RESULT:

The web application was successfully scanned using Nikto and OWASP ZAP. Several security vulnerabilities and configuration issues were identified, including missing anti-clickjacking headers, cookies without the SameSite attribute, missing security headers, and exposed directories/configuration files. The findings were reviewed according to their risk levels, and a structured vulnerability report was generated using OWASP ZAP.